DÜZCE ÜNİVERSİTESİ

2025-2026 AKADEMİK YILI BAHAR DÖNEMİ

SİSTEM GÜVENLİĞİ 312
SİSTEM GÜVENLİĞİ ANALİZ RAPORU

HAZIRLAYAN
Ad Soyad: Zeynep ÇETİN

ROL: SALDIRGAN VE SAVUNMACI

Bu çalışmada tek kişi hem saldırgan testlerini hem de savunma yapılandırmalarını gerçekleştirmiştir.

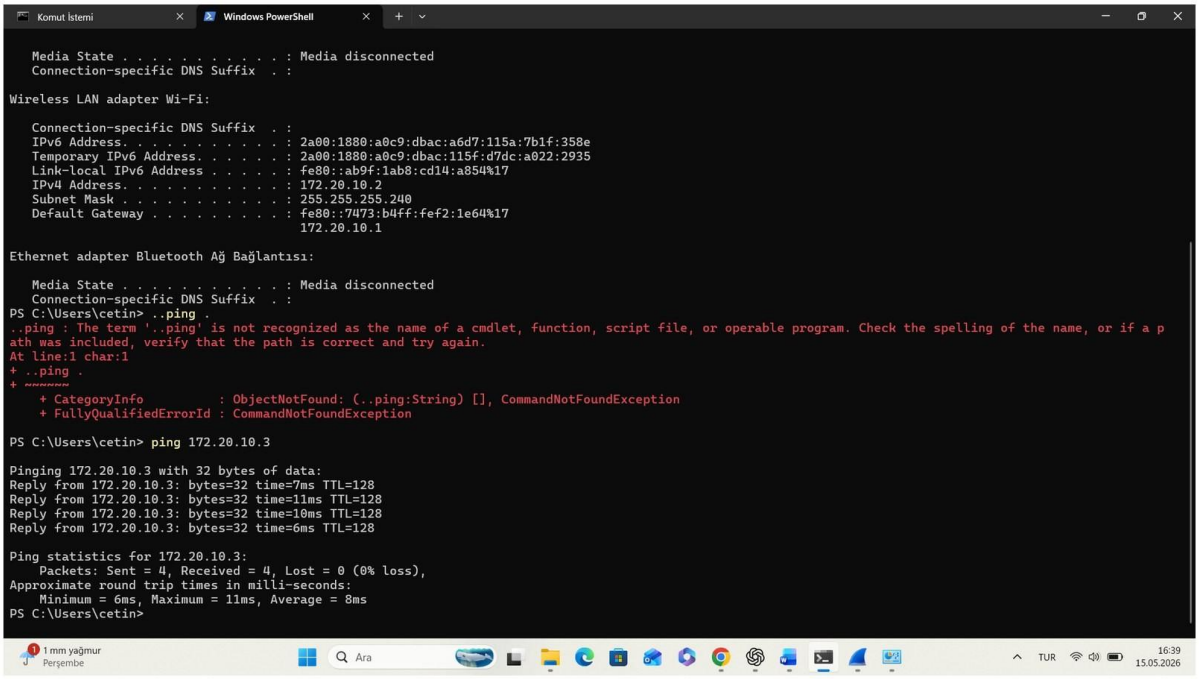
2) Giriş

Çalışmamızın amacı güvenlik analizi yapmak, açık portları ve çalışan servisleri belirlemek, ağ trafiğini gözlemlemek ve tespit edilen risklere karşı önlemler olarak savunma kurallarını oluşturmaktır. Analiz süreci saldırı ve savunma olmak üzere iki aşamada gerçekleşmiştir. Çalışmamızı 2 kişi olarak yürüttük ancak her iki rolü deneyimlemek için her birimiz hem saldırgan hem savunmacı olarak görev aldık. Çalışma eğitim amaçlı, kontrollü ağ ortamında gerçekleştirilmiştir. Amaç sisteme zarar vermek değil; port tarama, trafik gözlemi ve temel savunma yapılandırmalarını uygulamalı olarak göstermektir.

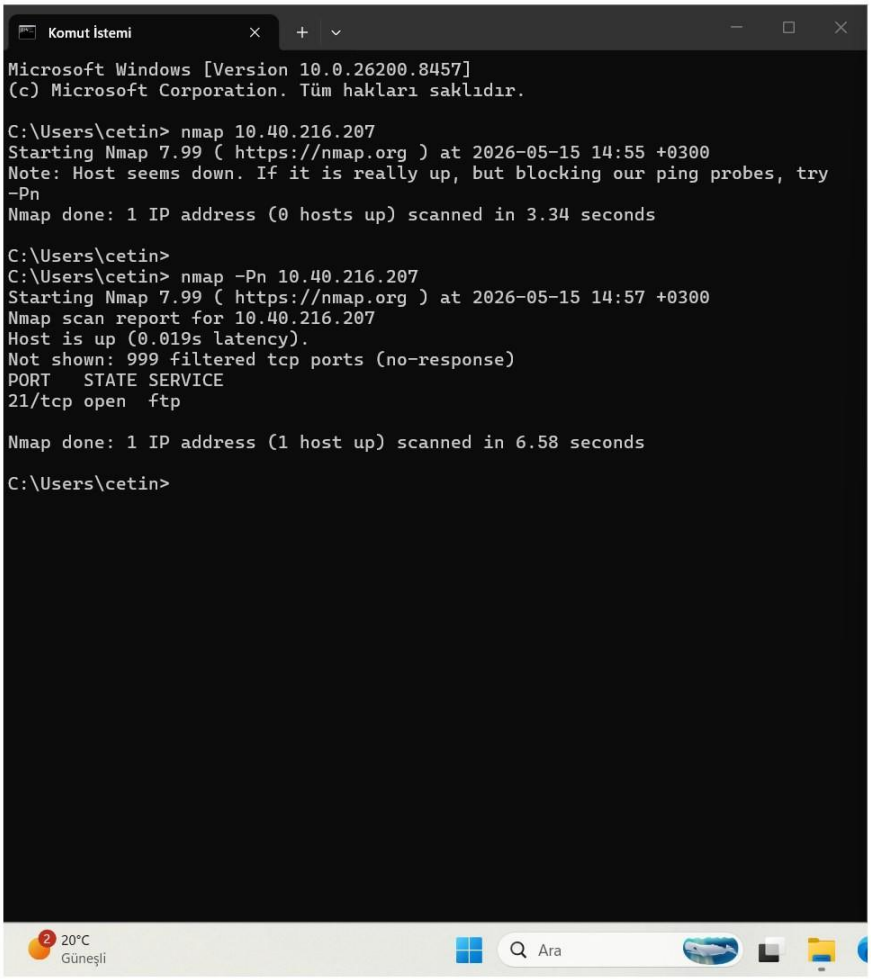
Rol	Yapılan işlem	Kullanılan araçlar
Saldırgan	Hedef sistemlerin erişilebilirliği kontrol edildi, port taraması yapıldı, HTTP/TLS bağlantı davranışları incelendi.	PowerShell, ping, Nmap, curl, Wireshark
Savunmacı	Güvenlik duvarı açık durumu kontrol edildi; TCP 135, 139 ve 445 portları için engelleme kuralları oluşturuldu.	Windows Defender Güvenlik Duvarı

3) Sistem Analizi

Sistem analizi aşamasında, aynı ağ üzerinde bulunan hedef sistemin IP bilgilerini belirledik; bunun için ana bilgisayarda Komut İstemi (CMD) açarak “ipconfig” komutunu çalıştırdık. Bu komut yardımıyla aktif ağ bağdaştırıcısı olan "Wireless LAN Adapter Wi-Fi" bölümünden analiz bilgisayarının IP adresi öğrenilmiştir. Analiz bilgisayarının IP adresi “172.20.10.2” olarak tespit edilmiştir. Tespit edilen cihazların hangi sisteme ait olduğunu belirlemek amacıyla cihazlara tek tek ping komutu gönderilmiştir. Yapılan işlemlerin sonucunda hedef test bilgisayarının IP adresinin “172.20.10.3” olduğu anlaşılmıştır.



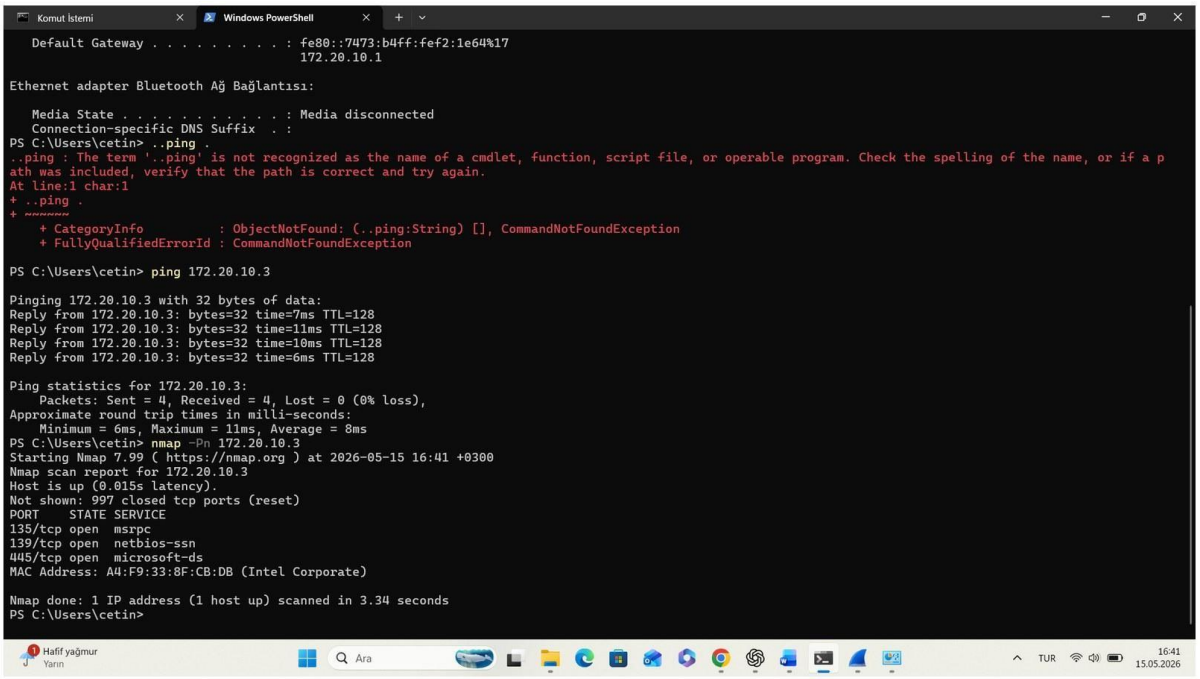
Şekil 1. Kendi sistem IP bilgisi ve 172.20.10.3 adresine yapılan ping testi.



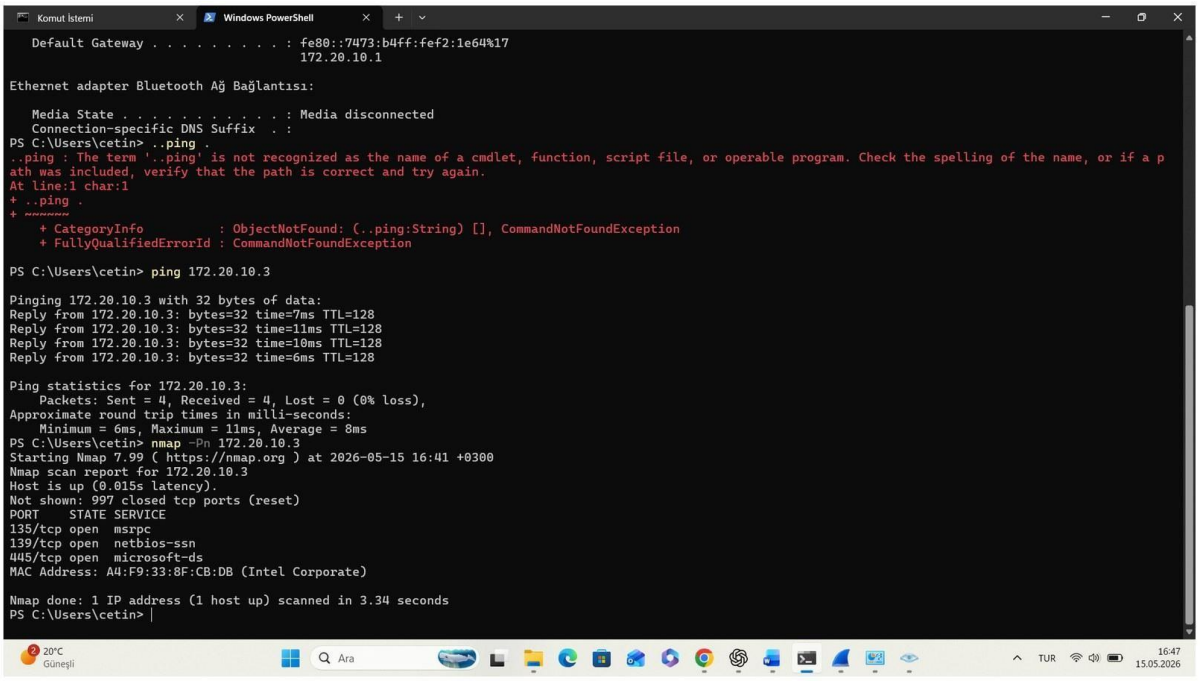
Şekil 2. Arkadaş bilgisayarına ilk bağlantı denemesinde güvenlik duvarı nedeniyle ping cevabı alınamaması ve -Pn ile tarama yapılması.

> **Not:** Bu bölüm, arkadaşımın bilgisayarına bağlanılamayan durumu rapora kanıt olarak ekler. Güvenlik duvarı ICMP/ping cevaplarını engellediği için sistem ilk taramada “host down” gibi görünmüştür.

Hedef sistemi belirledikten sonra Nmap taraması yapılmıştır. Kullandığımız komut “nmap 172.20.10.3”dür. Sonuç olarak 135/tcp, 139/tcp ve 445/tcp portlarının açık olduğu tespit edilmiştir. Bu portlar Windows RPC, NetBIOS ve SMB servisleriyle ilişkilidir. Yerel ağda açık olmaları dosya paylaşımı ve Windows servisleri açısından normal olabilir; fakat kontrolsüz bırakılmaları yetkisiz erişim ve bilgi sızması riski oluşturur.



Şekil 3. 172.20.10.3 üzerinde Nmap taraması; TCP 135, 139 ve 445 portlarının açık görünmesi.



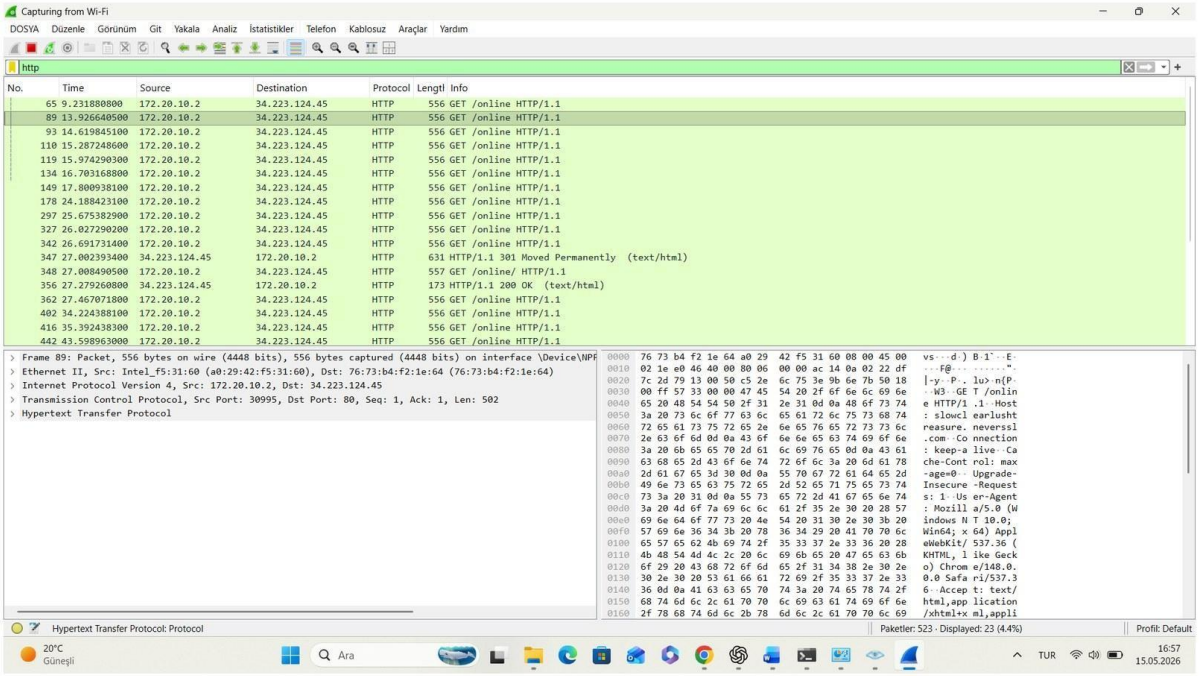
Şekil 4. Açık portların servis adlarıyla birlikte görülmesi: msrpc, netbios-ssn ve microsoft-ds.

Hedef IP	Tespit edilen durum	Açık port / servis	Değerlendirme
172.20.10.2	Kendi cihazım	Yerel IP bilgisi	Analiz ve savunma işlemleri bu cihazdan yürütüldü.
172.20.10.3	Ping başarılı, host erişilebilir	135/tcp msrpc, 139/tcp netbios-ssn, 445/tcp microsoft-ds	Windows servis portları açık; savunma kuralı gerektirir.

4) Trafik Analizi

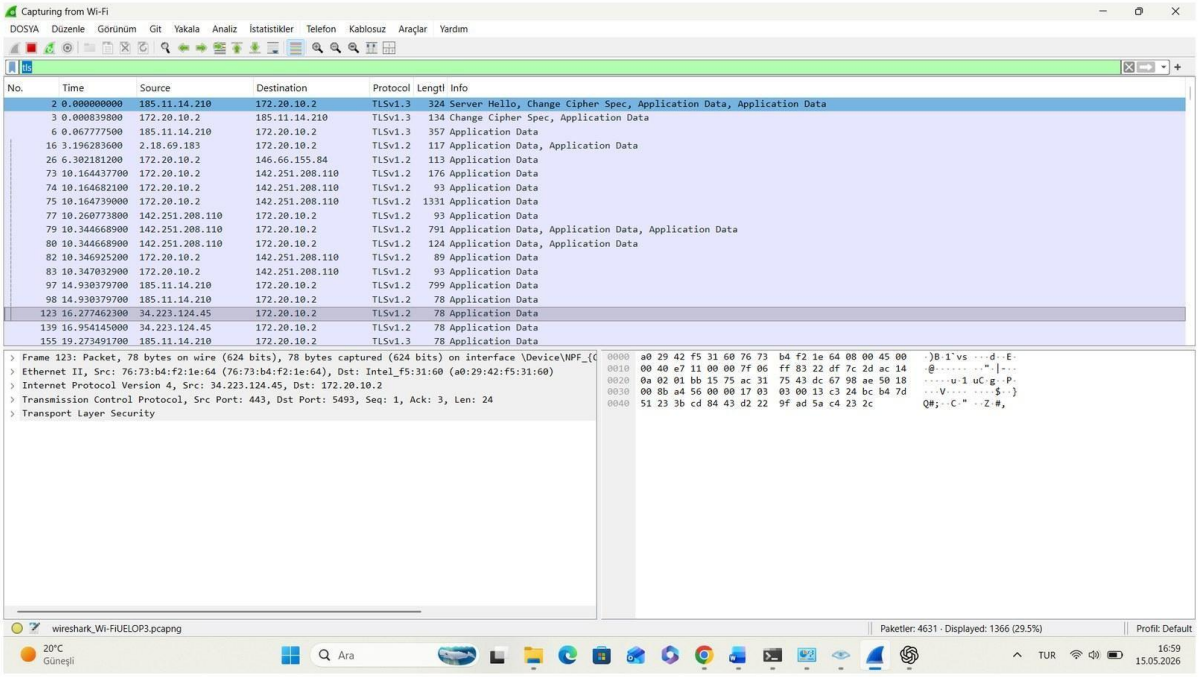
Bu bölümde trafik analizi Wireshark kullanılarak gerçekleştirilmiştir. Trafik analizi kapsamında HTTP paketleri gözlemlenmiştir. HTTP trafiği şifrelenmediği için paket içeriğinin okunabilir olması güvenlik açısından risk

oluşturur. Örnek kayıtlarda 172.20.10.2 kaynaklı isteklerin uzak sunuculara gittiği, GET /online isteği ve 301/200 gibi HTTP yanıtlarının yakalandığı görülmektedir.



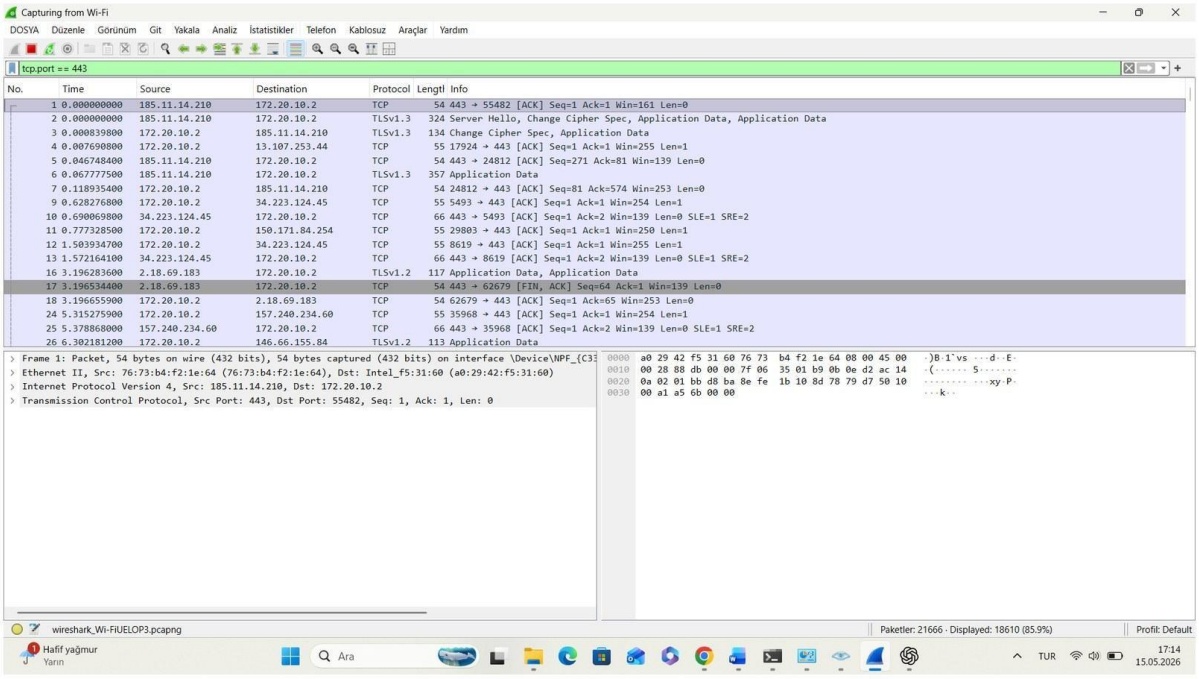
Şekil 5. Wireshark üzerinde HTTP filtresi ile GET isteklerinin görüntülenmesi.

TLS filtresi uygulandığında TLSv1.2 ve TLSv1.3 protokolleri üzerinden “Application Data” paketleri görülmüştür. Bu paketlerde içerik şifreli olduğu için uygulama verisinin açık şekilde okunamadığı gözlemlenmiştir. Bu durum HTTPS/TLS kullanımının gizlilik açısından HTTP’ye göre daha güvenli olduğunu göstermektedir.



Şekil 6. Wireshark üzerinde TLSv1.2/TLSv1.3 trafiğinin gözlemlenmesi.

tcp.port == 443 filtresi ile HTTPS trafiği ayrıştırılmıştır. 443 portu üzerindeki paketlerde TLS el sıkışması ve şifreli uygulama verisi akışı görülmektedir. Bu gözlem, ağ üzerinde web trafiğinin büyük kısmının TLS ile korunduğunu göstermektedir.

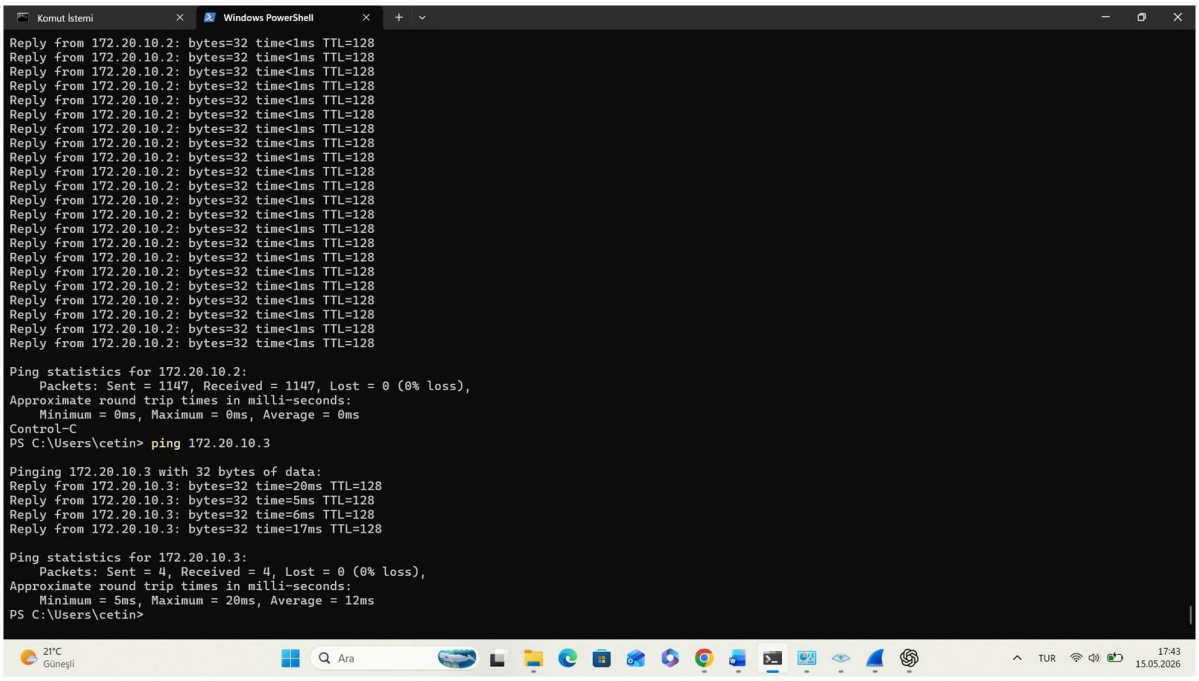


Şekil 7. Wireshark üzerinde 443 portu filtrelenerek HTTPS/TLS trafiğinin incelenmesi.

Analiz türü	Gözlem	Güvenlik yorumu
HTTP	GET istekleri ve bazı HTTP yanıtları okunabilir durumdadır.	Şifreleme olmadığı için paket içeriği görülebilir.
TLS	TLSv1.2 ve TLSv1.3 Application Data paketleri yakalanmıştır.	İçerik şifreli olduğu için doğrudan okunamaz.
tcp.port == 443	HTTPS bağlantıları port bazında ayrıştırılmıştır.	Güvenli web trafiği gözlenmiştir.
10.40.216.207 HTTP testi	curl ile port 80 bağlantısı başarısızdır.	Hedefte HTTP servisi yoktur veya firewall tarafından engellenmektedir.

5) Trafik Simülasyonu

Bu bölümde hedef cihazlara ping istekleri gönderilerek ağ erişilebilirliği ve cevap süreleri gözlemlenmiştir. Ping sonuçlarında paket kaybı olmaması, cihazların ilgili anda ağ üzerinde erişilebilir olduğunu göstermektedir. Amaç, ani istek artışının ağ trafiğine etkisini gözlemlemek, paket yoğunluğunu analiz etmek ve hedef sistemin yük altındaki davranışını değerlendirmektir.



Şekil 8. Ping ile bağlantı ve trafik gözlemi; paket kaybı ve cevap sürelerinin incelenmesi.

Ping testleri sırasında TTL=128 değerleri ve düşük milisaniye cevap süreleri yerel ağdaki Windows sistemlerinin hızlı şekilde yanıt verdiğini göstermiştir. Buna rağmen bazı hedeflerde güvenlik duvarı açık olduğunda ICMP cevapları alınamamış; bu durum Nmap taramalarında “host seems down” uyarısı olarak görülmüştür.

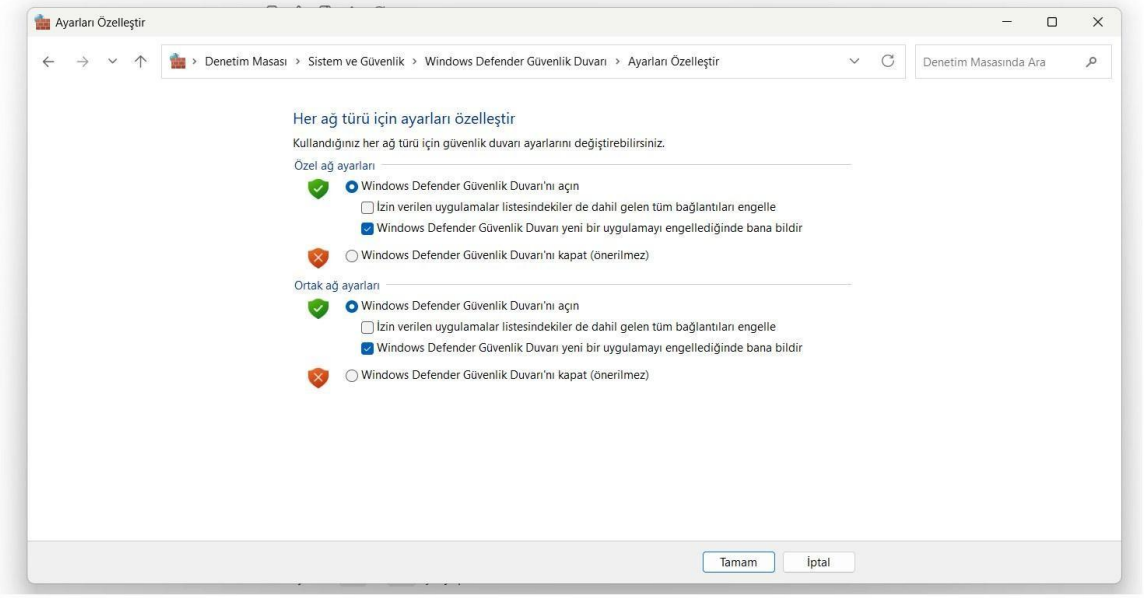
6) Güvenlik Açığı Değerlendirmesi

Bu bölümde önceki aşamalarda yapılan sistem analizi, port taraması, servis incelemesi ve trafik analizlerinden elde edilen veriler kullanılarak aşağıdaki tablo oluşturulmuştur.

Bulgu	Risk	Açıklama	Önerilen savunma
TCP 135 açık	Orta/Yüksek	MSRPC servisi ağ üzerinden erişilebilir olabilir.	Gelen bağlantıları sınırlandır veya engelle.
TCP 139 açık	Orta/Yüksek	NetBIOS oturum servisi açık olabilir.	NetBIOS erişimini güvenilir ağlarla sınırlandır.
TCP 445 açık	Yüksek	SMB/Microsoft-DS portu dosya paylaşımı ve uzak erişim açısından kritiktir.	SMB erişimini kapat veya sadece güvenilir IP adreslerine izin ver.
FTP 21 açık	Orta	FTP kimlik bilgilerini şifresiz aktarabilir.	Mümkünse SFTP/FTPS kullan veya erişimi kısıtla.
HTTP 80 kapalı/erişilemiyor	Düşük	HTTP servisi hedefte çalışmıyor veya firewall tarafından engelleniyor.	Gereksiz servislerin kapalı tutulması olumlu bir durumdur.
TLS trafiği mevcut	Düşük	Şifreli veri akışı gözlenmiştir.	TLS kullanımı sürdürülmeli; zayıf sürümler devre dışı bırakılmalıdır.

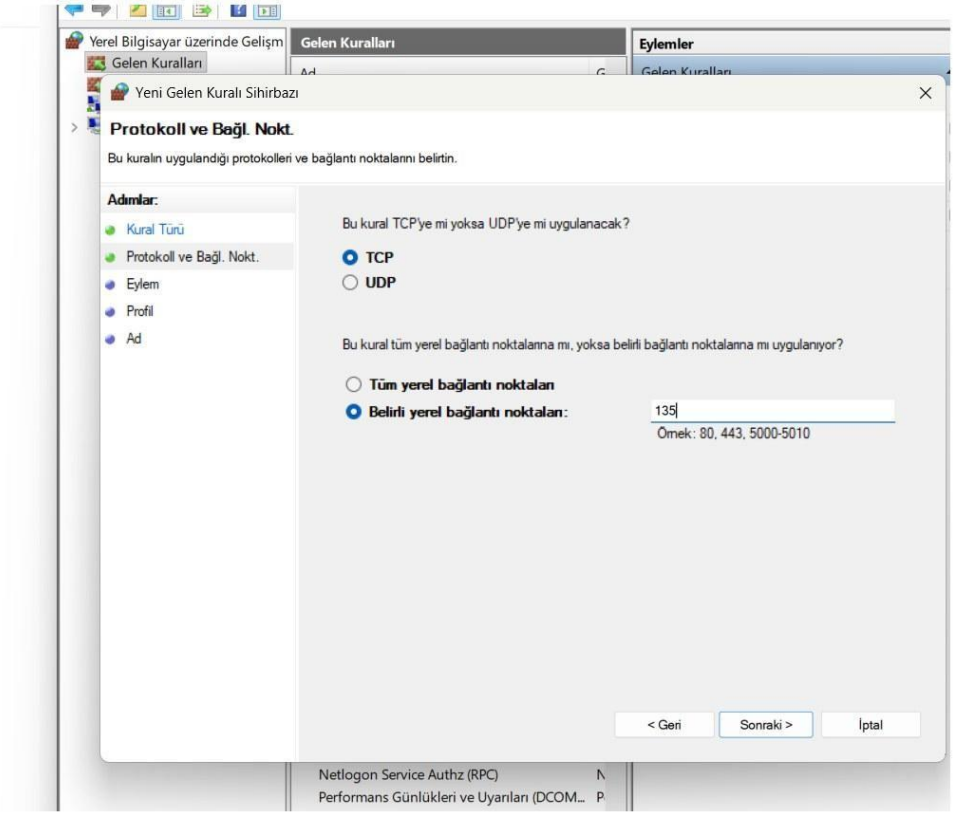
7) Güvenlik Önlemleri

Bu bölümde savunmacı rolune geçilmiştir.Windows Defender Güvenlik Duvarı control edilmiştir. Özel ve ortak ağ profillerinde güvenlik duvarının açık olduğu görülmüştür. Yani yetkisiz bağlantılara karşı temel koruma aktif haldedir.

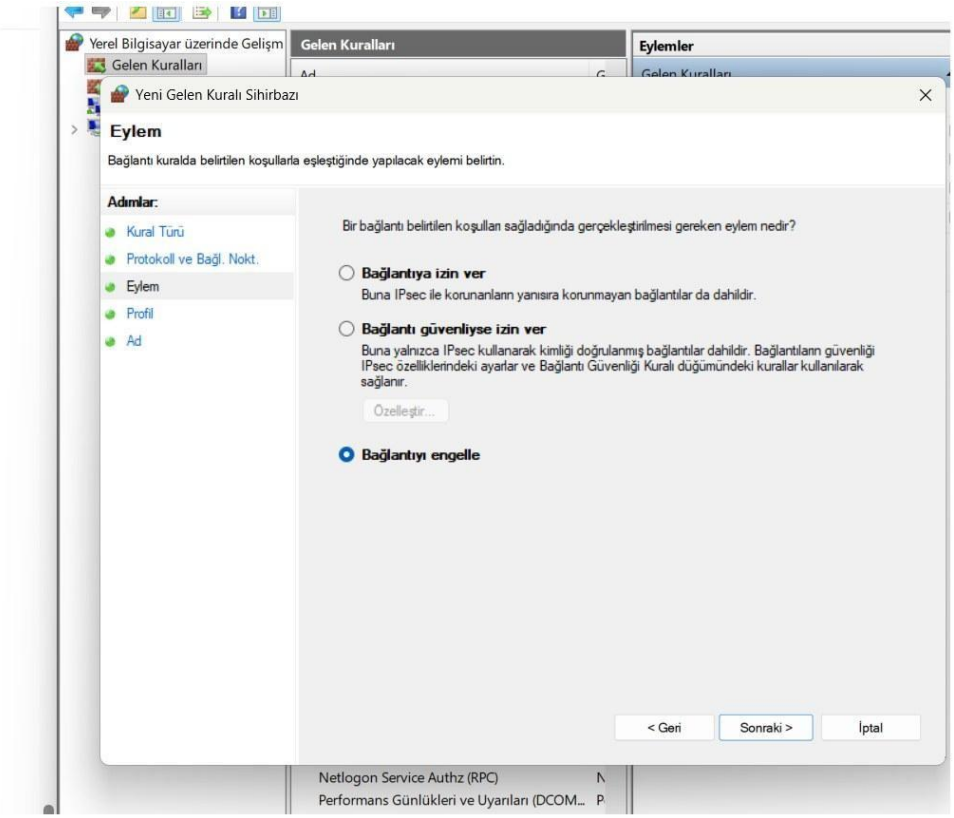


Şekil 9. Windows Defender Güvenlik Duvarı ayarlarında özel ve ortak ağ için güvenlik duvarının açık olması.

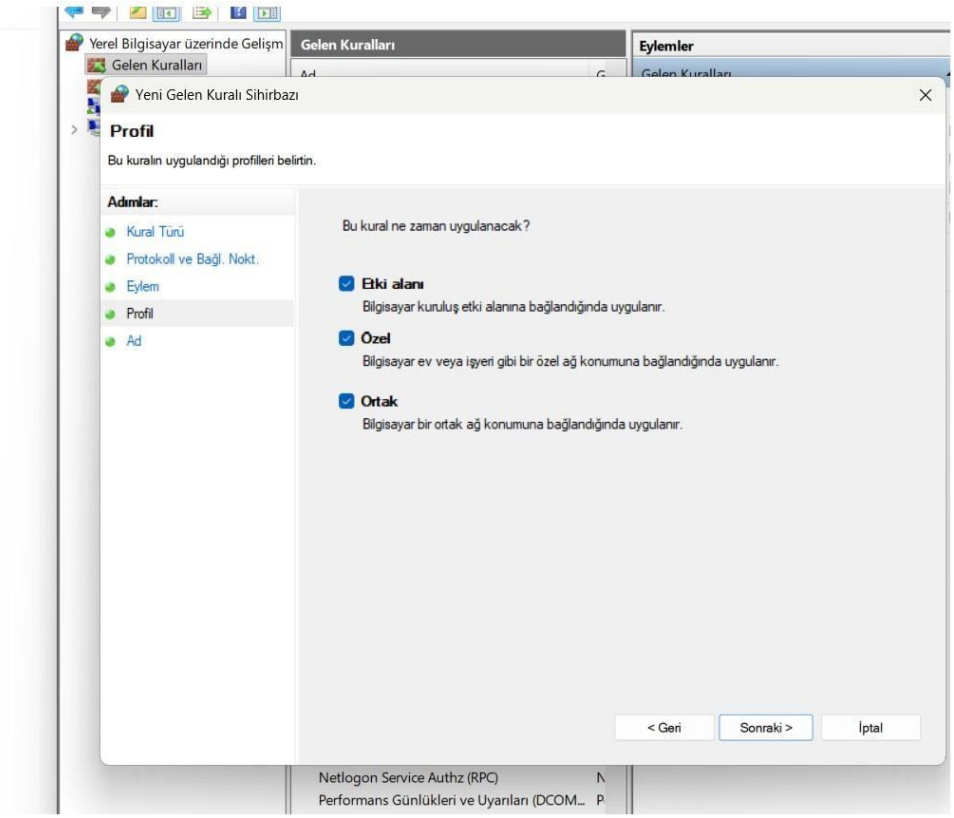
Riskli görülen Windows servis portları için gelen bağlantı kuralları oluşturulmuştur. Kural tipi olarak “Port”, protokol olarak “TCP” seçilmiş; 135, 139 ve 445 portları ayrı ayrı engellenecek şekilde yapılandırılmıştır. Portların ayrı kural olarak tanımlanması, hangi servisin engellendiğini raporda daha anlaşılır hale getirmiştir.



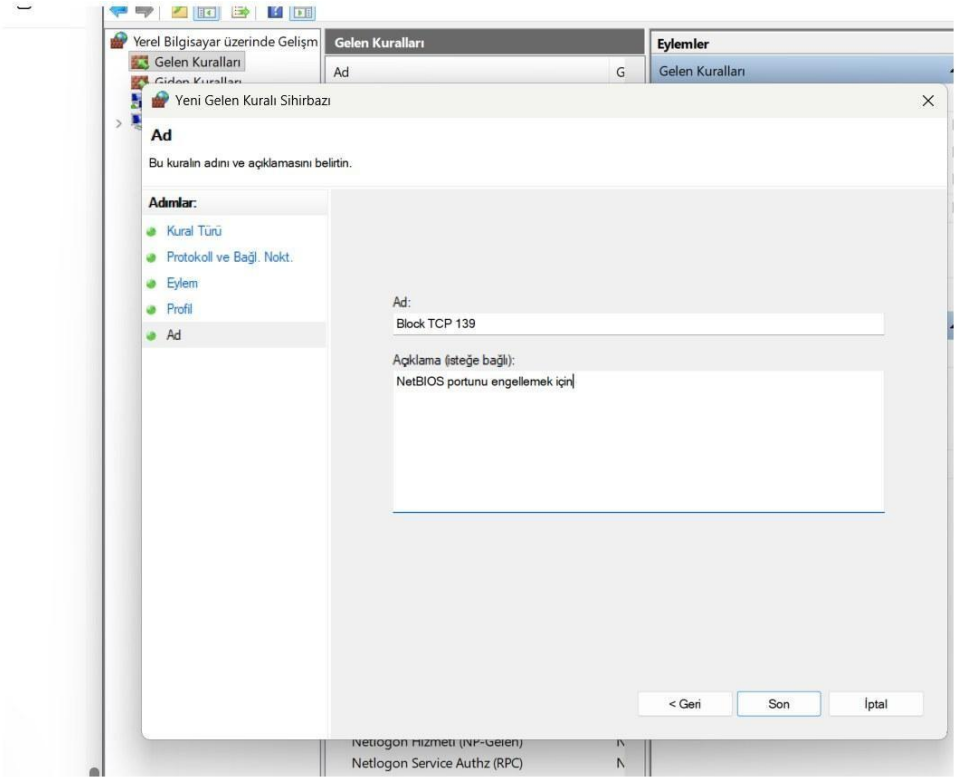
Şekil 10. Yeni gelen kural sihirbazında TCP protokolü ve belirli yerel port seçimi.



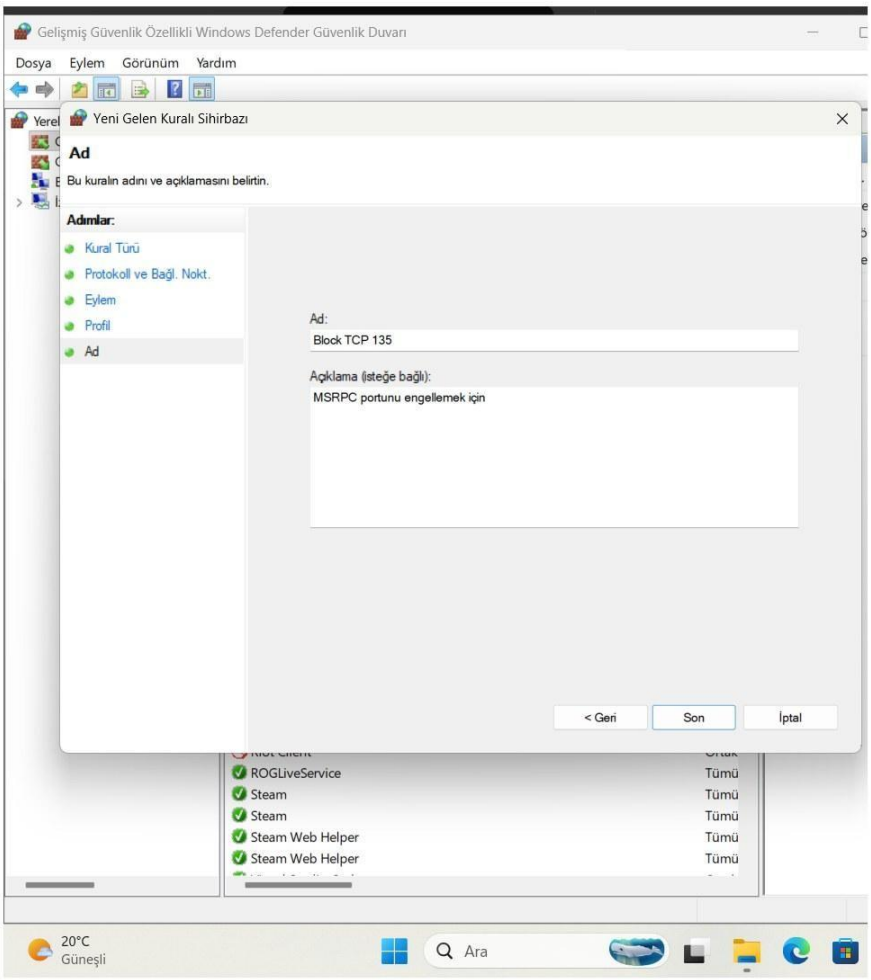
Şekil 11. Kural eylemi olarak "Bağlantıyı engelle" seçilmesi.



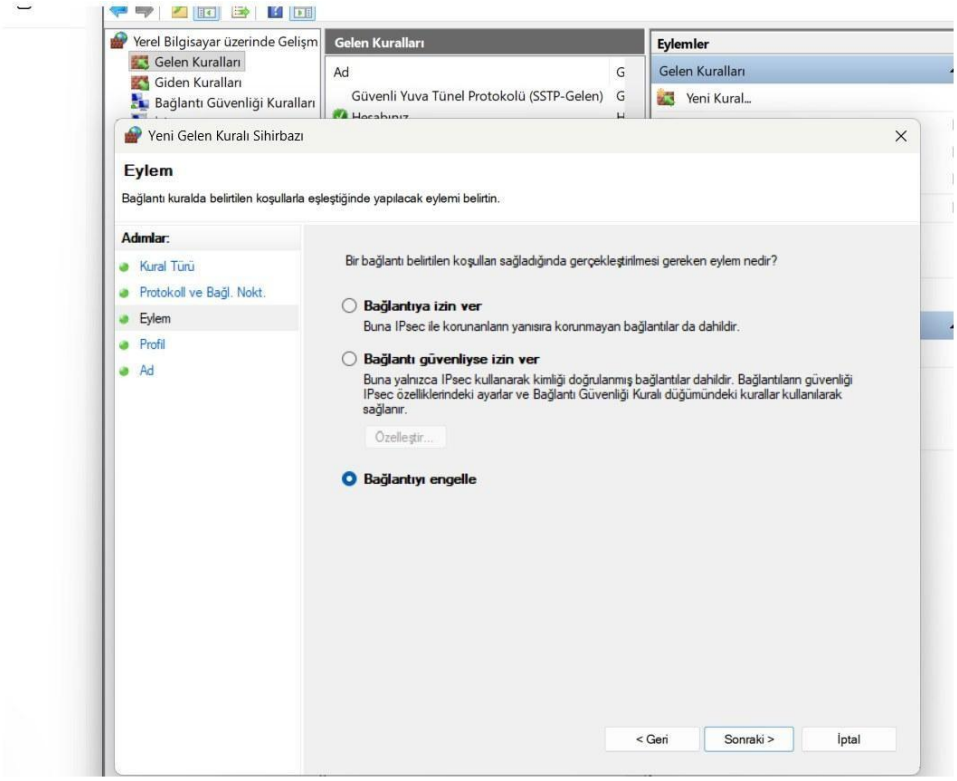
Şekil 12. Kuralın Etki Alanı, Özel ve Ortak profillerde geçerli olacak şekilde seçilmesi.



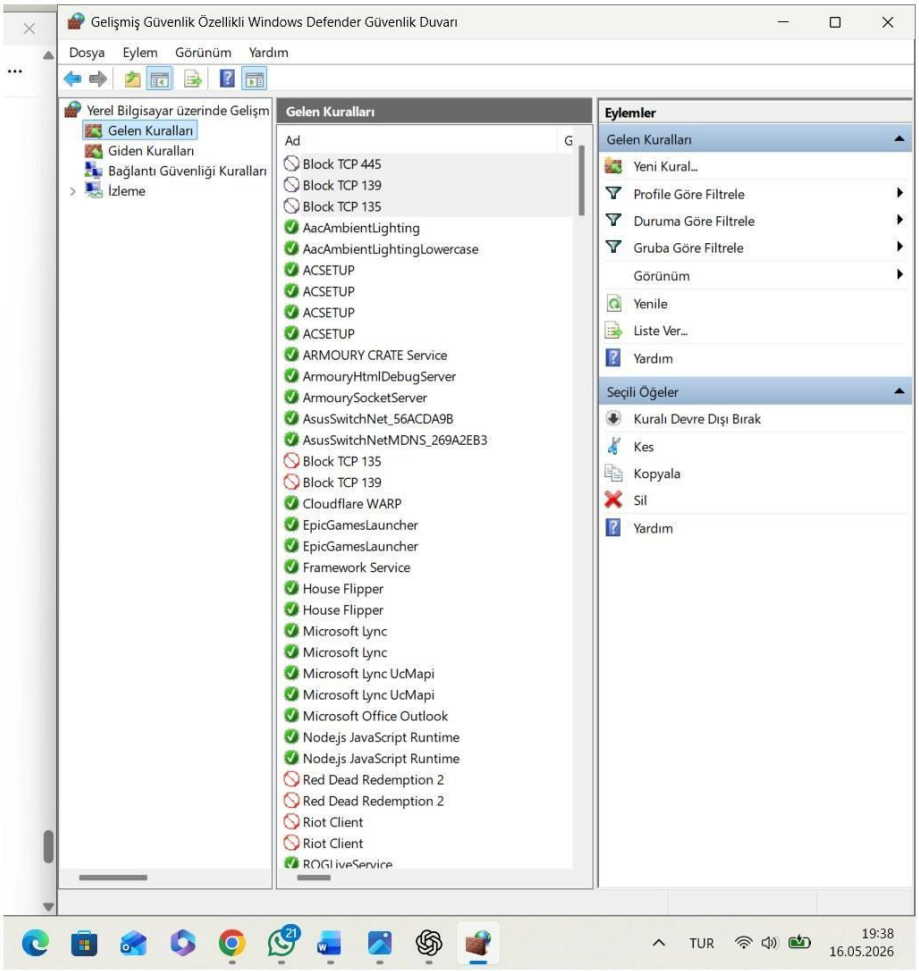
Şekil 13. TCP 135 için "Block TCP 135" adlı engelleme kuralının oluşturulması.



Şekil 14. TCP 139 için "Block TCP 139" adlı engelleme kuralının oluşturulması.



Şekil 15. Kural sihirbazında engelleme eyleminin ve kural adımlarının doğrulanması.



Şekil 16. Gelen kurallar listesinde Block TCP 445, Block TCP 139 ve Block TCP 135 kurallarının görünmesi.

Port	Kural adı	Amaç	Savunma etkisi
135/tcp	Block TCP 135	MSRPC erişimini engellemek	RPC üzerinden gelebilecek yetkisiz bağlantıları azaltır.
139/tcp	Block TCP 139	NetBIOS oturum trafiğini engellemek	Ağ paylaşımı keşfi ve eski Windows paylaşım risklerini sınırlar.
445/tcp	Block TCP 445	SMB/Microsoft-DS erişimini engellemek	SMB tabanlı yetkisiz erişim ve yayılma riskini azaltır.

Kural listesinde engelleme işaretli Block TCP kurallarının görünmesi, savunma yapılandırmasının Windows Defender Güvenlik Duvarı üzerinde tanımlandığını gösterir. Engelleme kurallarının aktifliği, hedefe tekrar Nmap taraması yapılarak portların closed/filtered durumuna geçip geçmediğiyle ayrıca doğrulanabilir.

8) Genel Değerlendirme

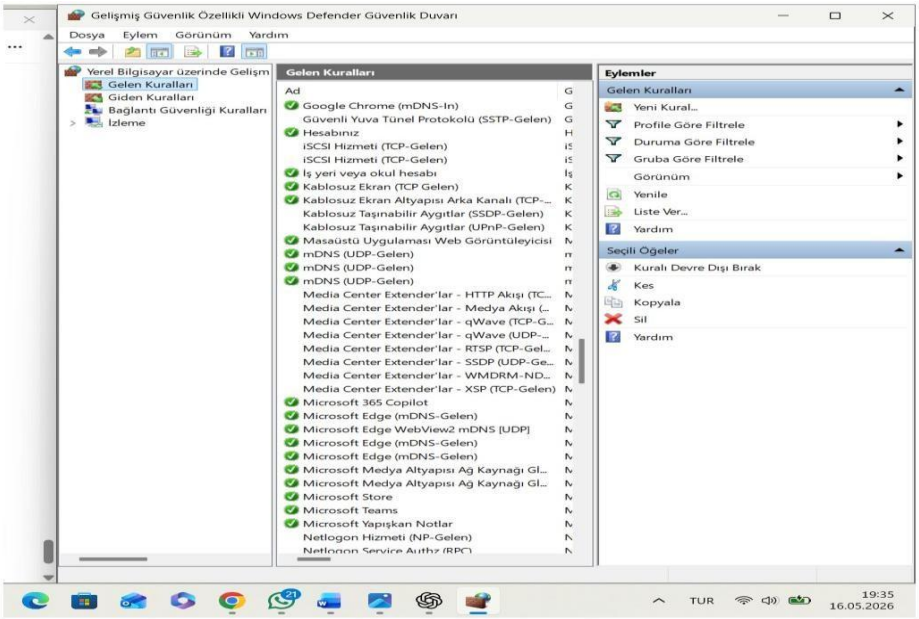
Çalışmanın saldırgan aşamasında IP bilgileri, hedef sistem erişilebilirliği, açık portlar ve servisler belirlenmiştir. Savunma aşamasında ise açık görülen kritik Windows servis portlarına karşı güvenlik duvarı kuralları tanımlanmıştır. Böylece rapor hem keşif hem de savunma adımlarını tek kişi tarafından uygulanmış şekilde göstermektedir.

9) Sonuç

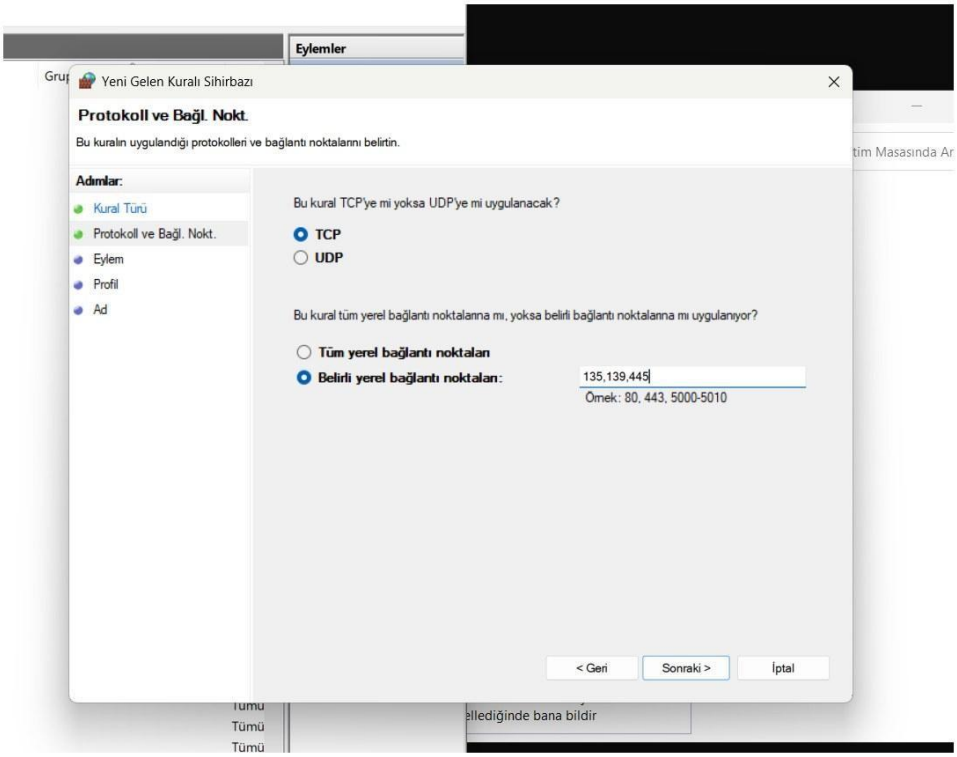
Bu çalışmada saldırgan ve savunmacı roller deneyimlenmiştir. Saldırgan rolündeyken Nmap, ping, curl ve Wireshark kullanılarak hedef sistemdeki port ve trafik analizleri incelenmiştir. Savunmacı rolünde ise Windows Defender Güvenlik Duvarı üzerinden riskli portlar engellenmiştir. Bu çalışmada elde ettiğimiz çıkarımlardan biri, güvenlik duvarının hedef sistemlerin görünürlüğünü ve erişilebilirliğini doğrudan etkilediğidir. Bunu, arkadaşımın bilgisayarındaki güvenlik duvarını kaldırmayı unutup ping denemelerimizin başarısız olması sayesinde test etmiş olduk.

10) Ekler

Aşağıda raporda kullanılan ve teknik süreci destekleyen ek ekran görüntüleri verilmiştir.



Şekil 17. Windows Defender gelen kurallar ekranında kural listesinin genel görünümü.



Şekil 18. Port kuralı oluşturma sırasında çoklu port girme denemesi; nihai raporda portlar ayrı kural olarak değerlendirilmiştir.